# ETHICAL HACKING 361

Milestone 3

## Table of Contents

Introduction ..... 2
Initial Setup and Creating the Vulnerability ..... 3
Step 1: Create a Low-Privilege User ..... 3
Step 2: Create the SUID Misconfiguration (The Vulnerability) ..... 5
The Privilege Escalation Attack ..... 6
Step 1: Log in as the Low-Privilege User ..... 6
Step 2: Verify Initial Low-Privilege Status (The "Before" Picture) ..... 6
Step 3: Find SUID Binaries on the System (Reconnaissance) ..... 6
Step 4: Exploit the SUID Binary to Gain a Root Shell (The Attack) ..... 8
Step 5: Verify Successful Privilege Escalation ..... 8
Proof of Success: ..... 9
References ..... 10

# Introduction

Privilege Escalation is the act of exploiting a bug, design flaw, or configuration oversight in an operating system or software application to gain elevated access to resources that are normally protected from an application or user (OWASP, 2023). This demonstration will escalate from a low-privilege user to the root user on a Kali Linux system.

The chosen attack vector is the exploitation of a **Set User ID (SUID)** binary. When a binary has the SUID bit set, it executes with the permissions of the file owner (in our case, root), not the user who runs it. We will simulate a scenario where a system administrator has incorrectly set the SUID bit on the /usr/bin/find utility, creating a critical vulnerability.

# Initial Setup and Creating the Vulnerability

For this attack to work, we first need to simulate the environment: a low-privilege user on a system with a specific misconfiguration.

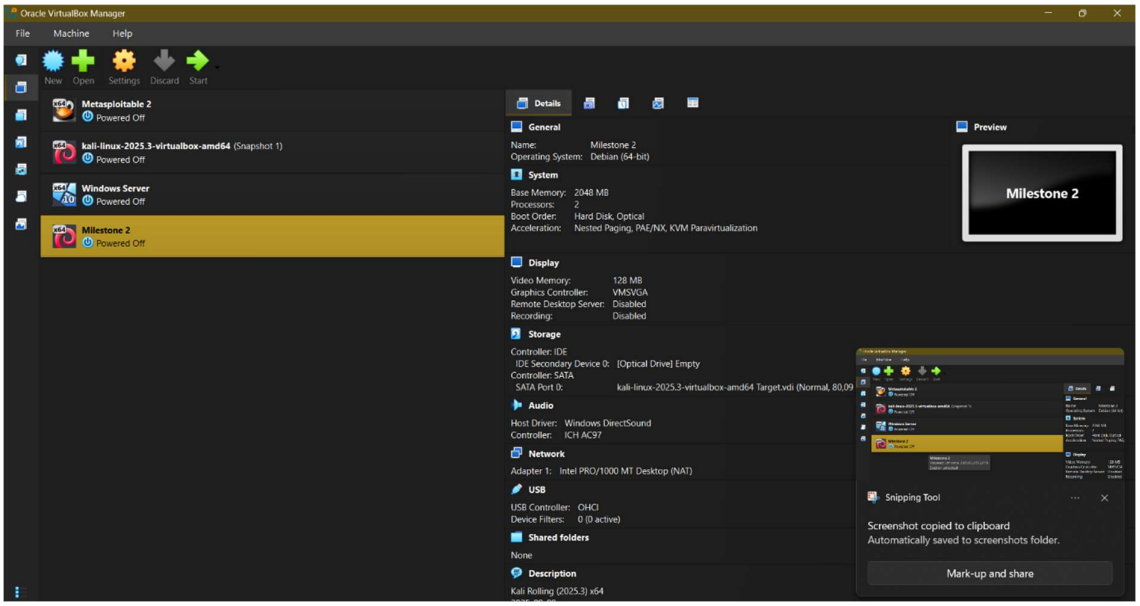
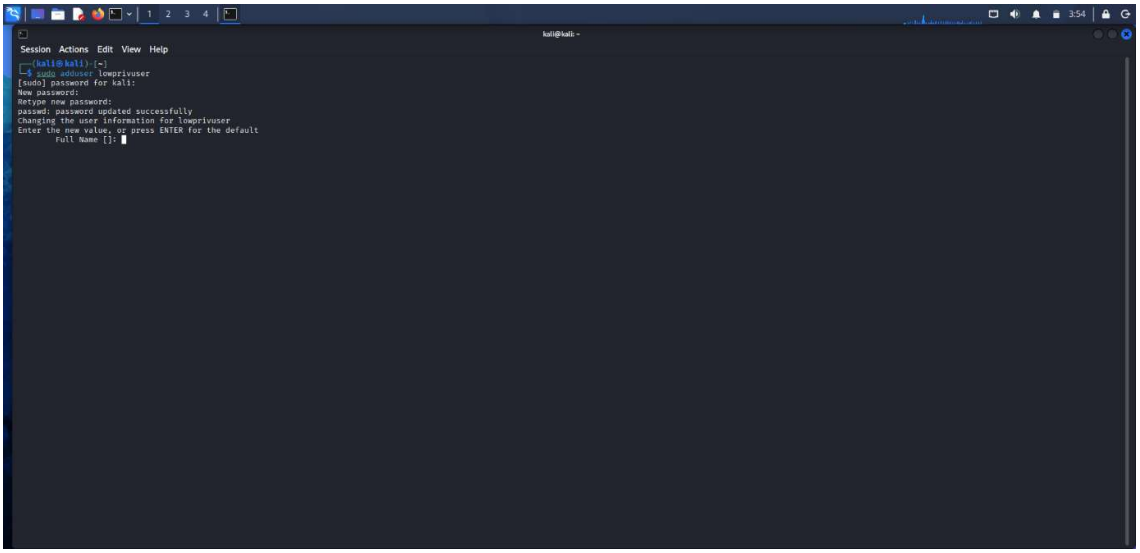



*Figure 1: Kali Linux "Milestone2" Virtual Machine*

## Step 1: Create a Low-Privilege User

First, we need a non-root user to escalate *from*.

- **Command: *sudo adduser lowprivuser***
- **Explanation:** This command creates a new standard user named lowprivuser. You will be prompted to set a password and fill in some user information.



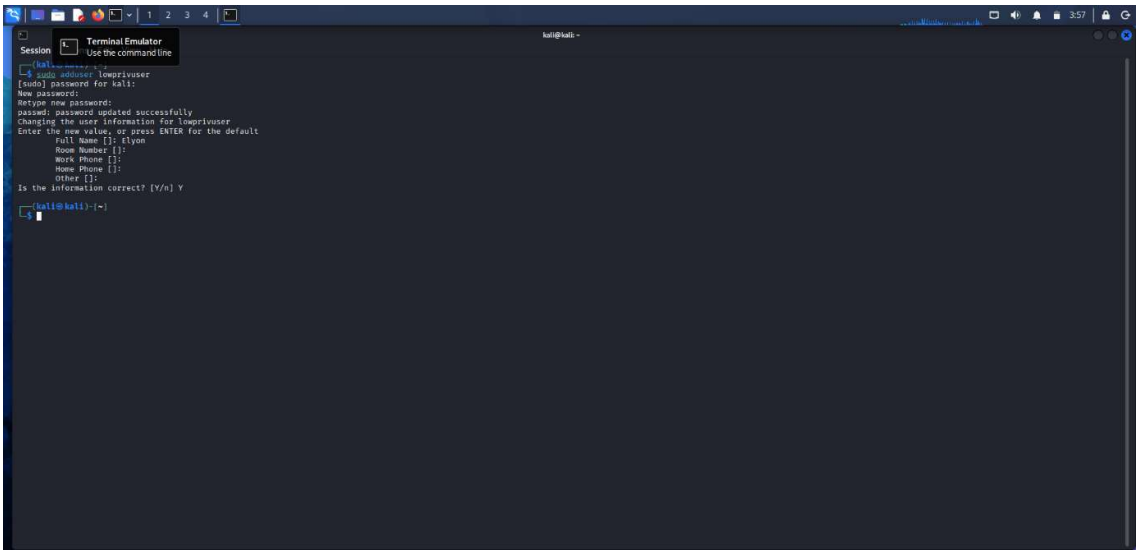



*Figure 2: Creating the lowprivuser*

## Step 2: Create the SUID Misconfiguration (The Vulnerability)

This is the crucial step where we, acting as an administrator, make a "mistake".

- **Command: *sudo chmod u+s /usr/bin/find***
- **Explanation:**
    - sudo: Executes the command with root privileges.
    - chmod: "Change Mode", a command to change file permissions.
    - u+s: This is the key part. It **adds (+)** the **SUID bit (s)** to the **user (u)** permissions of the file.
    - /usr/bin/find: The target binary. find is a powerful utility for searching for files.

After running this, the find command will now execute as root no matter who runs it.

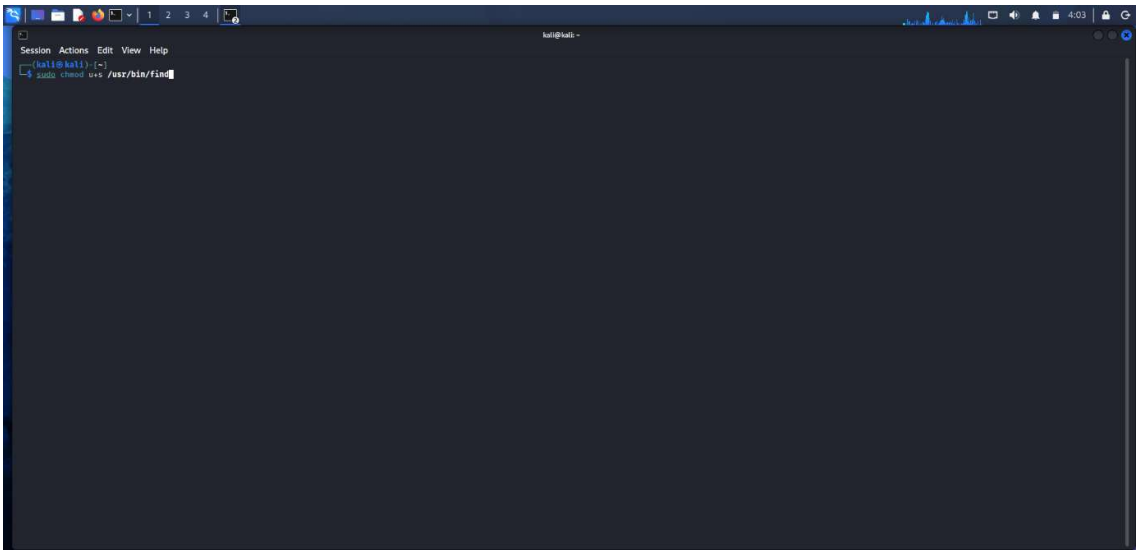



*Figure 3: Setting the SUID bit on the find binary*

# The Privilege Escalation Attack

## Step 1: Log in as the Low-Privilege User

**we switch to the attacker's perspective, logged in as the low-privilege user.**

**Open a new terminal or switch user.**

- **Command: *su lowprivuser***
- **Explanation: su (Switch User) command logs you into the lowprivuser account. Enter the password you created.**

## Step 2: Verify Initial Low-Privilege Status (The "Before" Picture)

**This proves we are not root.**

- **Commands:**
  - **whoami: Prints the current user's name.**
  - **id: Prints the user and group IDs.**

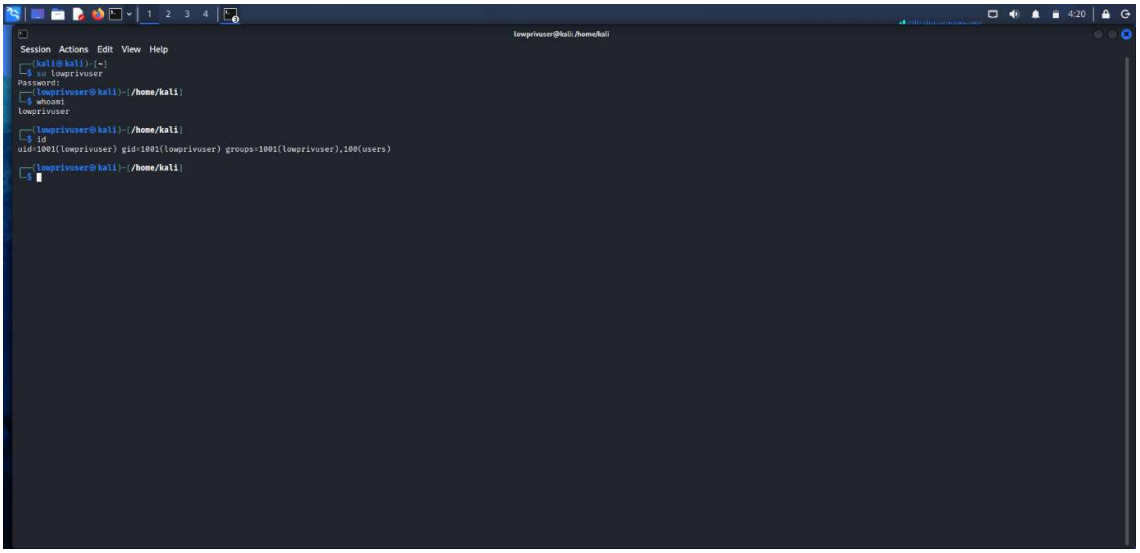



*Figure 4: Verifying initial low-privilege access.*

## Step 3: Find SUID Binaries on the System (Reconnaissance)

**An attacker would now hunt for potential vulnerabilities. A primary target is SUID binaries.**

- **Command: *find / -perm -u=s -type f 2>/dev/null***
- **Explanation:**
  - **find /: Search the entire filesystem starting from the root directory (/).**

- **-perm -u=s: Find files where the permission (-perm) has the SUID bit set for the user (-u=s).**
- **-type f: Only look for files (f), not directories.**
- **2>/dev/null: Redirects any "Permission denied" errors to /dev/null (a black hole), cleaning up the output.**

- **Expected Output: You will see a list of SUID binaries. Our vulnerable /usr/bin/find will be among them, often highlighted in red.**

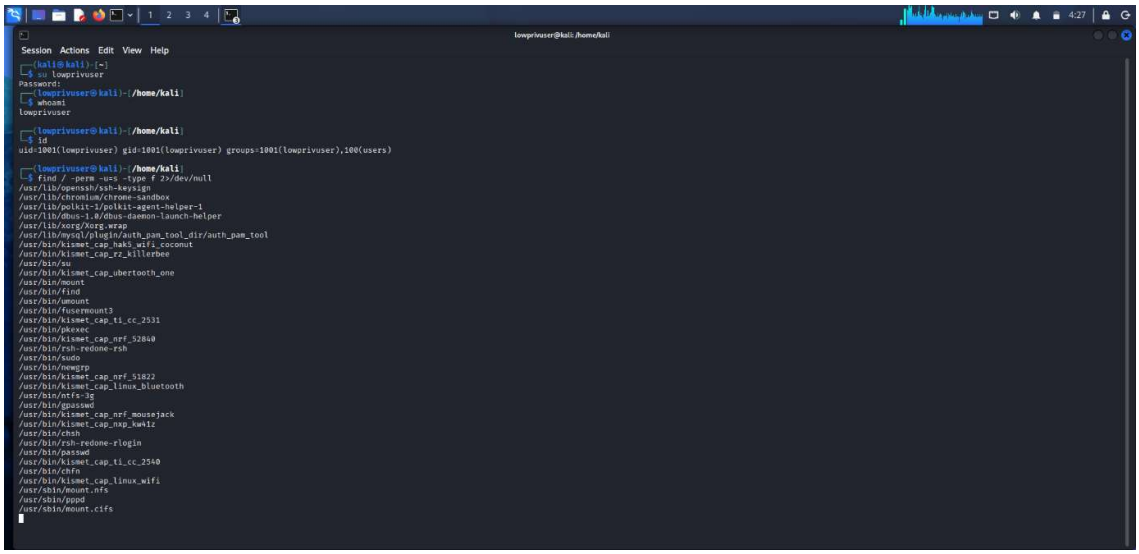



*Figure 5: Discovering the vulnerable find binary.*

## Step 4: Exploit the SUID Binary to Gain a Root Shell (The Attack)

We will now use find's -exec option to launch a shell. Because find is running as root, the shell it launches will also be a root shell. This technique is well-documented on resources like GTFOBins (n.d.).

- **Command:** ***find . -exec /bin/sh -p \; -quit***
- **Explanation:**
    - find .: We run find on the current directory (.). The target doesn't matter.
    - -exec /bin/sh -p: This is the exploit. The -exec action tells find to execute a command. We execute /bin/sh (a shell).
    - -p: This flag is **critical**. It tells the shell *not* to drop its effective UID if it doesn't match the real UID. Without -p, the shell would start as lowprivuser. With -p, it retains the root permissions inherited from the SUID find binary.
    - \; -quit: Terminates the find command after the shell is launched.

## Step 5: Verify Successful Privilege Escalation

After running the command above, you will be dropped into a new shell prompt, which looks like #. Now, we run the same verification commands as before.

- **Commands:**
    - whoami
    - id

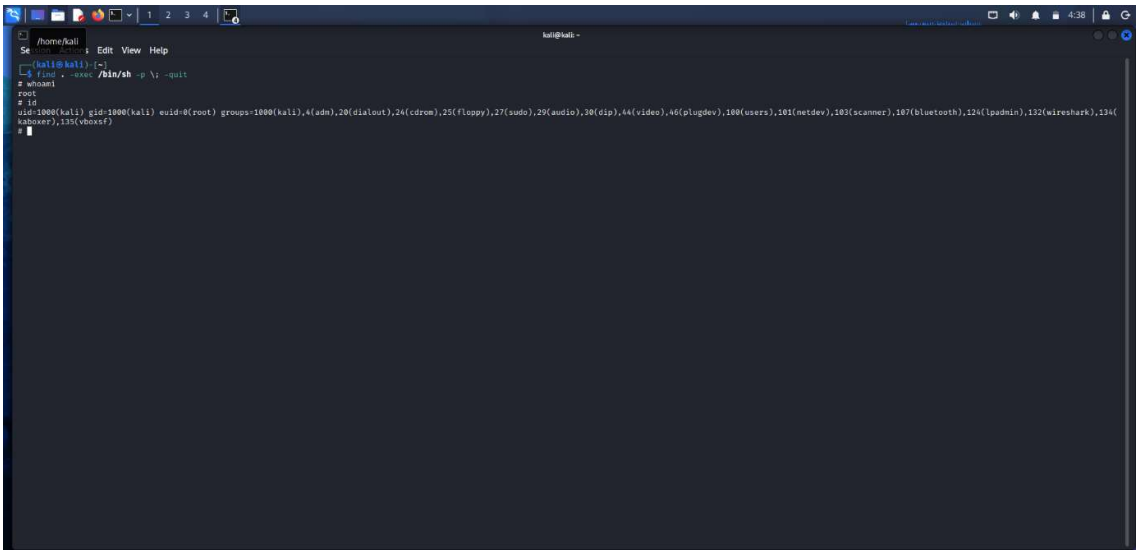



*Figure 6: Proof of successful root access*

## Proof of Success:

1. The prompt changes from $ to #, the universal sign of a root shell.
2. whoami returns root.
3. id shows that our **Effective User ID (**euid**) is 0 (root)**, even though our real UID is still lowprivuser. We are now executing commands with the full power of the root user.

# References

hexdump. (2024, May 31). *Introduction to the Linux Shell*. Retrieved from Youtube: https://www.youtube.com/watch?v=YDoKDEfugI4&list=PLJnLaWkc9xRiI6UxygcxrsqIza3KhRy4v

Mentor, T. C. (2023, February 03). *Linux Privilege Escalation for Beginners*. Retrieved February 24, 2026, from Youtube: https://www.youtube.com/watch?v=ZTnwg3qCdVM

peddle. (2024, July 22). *How Hackers Gain Root Access | Linux Privilege Escalation*. Retrieved from Youtube: https://www.youtube.com/watch?v=RFebj52xrLU

WireDogSec. (2024, june 25). *Linux Privilege Escalation! | TryHackMe - Jr Penetration Tester*. Retrieved from Youtube: https://www.youtube.com/watch?v=vRMrk82Tvtk